

République Tunisienne

Ministère de l'Enseignement Supérieur
et de la Recherche Scientifique

École Supérieure Privée d'ingénierie et de technologie

TEK-UP

Rapport de Projet
Art-protection-secrets

Spécialité : Sécurité des Systèmes Informatiques et Réseaux

Réalisés par

Sarra Ghliss

ING-5-SSIRF-B

Infrastructure réseau et postes sécurisés

Table des matières

Introduction générale **1**

1 Contexte, besoins et conception de l'infrastructure **2**

1.1 Contexte et problématique 2

1.2 Objectifs du projet 2

1.3 Besoins fonctionnels et exigences de sécurité 3

1.4 Architecture générale 3

1.5 Plan d'adressage IP 4

1.6 Justification des choix technologiques 5

1.7 Conclusion 5

2 Implémentation et durcissement de l'infrastructure **6**

2.1 Présentation et description de l'architecture réseau sous EVE-NG 6

2.2 Configuration du pare-feu et segmentation réseau 7

2.3 Mise en place du serveur Web et de DVWA 10

2.4 Sécurisation de SSH et gestion des privilèges 11

2.5 Rapport de durcissement des systèmes Linux 12

2.5.1 Objectif et périmètre 12

2.5.2 État initial observé 12

2.5.3 Mise à jour du système 14

2.5.4 Inventaire et réduction des services 14

2.5.5 Installation des outils de sécurité complémentaires 14

2.5.6 2.4.5 Renforcement du serveur Web Apache 15

2.5.7 Audit final avec Lynis 16

2.5.8 Tableau de synthèse du durcissement 17

2.6 Détection réseau avec Suricata 18

2.7 Supervision et centralisation avec Wazuh 18

2.8 Dashboard intelligent basé sur l'IA 20
2.9 Conclusion 21

3 Tests, résultats et évaluation de la sécurité 22
3.1 Méthodologie de validation 22
3.2 Tests Nmap avant et après durcissement 22
3.3 Tests applicatifs avec DVWA 23
3.4 Résultats du durcissement 25
3.5 Évaluation du durcissement de l'infrastructure 25
3.5.1 Sécurisation des systèmes Linux 25
3.5.2 Contrôle des communications réseau 26
3.5.3 Supervision et traçabilité 26
3.6 Limites et perspectives 26
3.7 Conclusion 26
3.7.1 Cohérence de l'analyse intelligente 27

Conclusion générale 28

Table des figures

1.1 Topologie générale de l'infrastructure EVE-NG 4
1.2 Les interfaces pfsense 5

2.1 Architecture EVE-NG 6
2.2 Regles filtrage WAN 8
2.3 Regles de filtrage client lan 8
2.4 regles filtrage DMZ 9
2.5 regles filtrage MGMT 10
2.6 page de connexion DVWA 11
2.7 Paramètres effectifs de SSH 11
2.8 Résultat initial de Lynis 13
2.9 Scan Nmap initial 13
2.10 verification des mises a jour 14
2.11 Installation et vérification des outils de sécurité 15
2.12 politique serveur ssh 16
2.13 Résultat final de Lynis 17
2.14 Exemple d'alerte Suricata 18
2.15 etat des agents wazuh 19
2.16 Exemple d'alerte Wazuh sur dmz 19
2.17 Vue générale du dashboard IA 20

3.1 Scan nmap apres durcissement 23
3.2 SQL Injection sur DVWA depuis kali 24
3.3 Alerte de sécurité correspondante 24

Liste des tableaux

1.1 Besoins fonctionnels et exigences de sécurité 3
1.2 Plan d'adressage IP du laboratoire 4
1.3 Technologies utilisées et rôle de chacune 5

2.1 Politique de filtrage attendue 7
2.2 Synthèse du durcissement 17

3.1 Résultats du durcissement et validations restantes 25

Introduction générale

La sécurité des infrastructures informatiques représente un enjeu essentiel pour les entreprises. Les postes utilisateurs, les serveurs Web et les équipements réseau peuvent être exposés à des tentatives d'accès non autorisées, à des activités de reconnaissance, à des attaques applicatives et à l'exploitation de vulnérabilités. Une mauvaise segmentation réseau, des services inutilement exposés et des privilèges excessifs peuvent augmenter les risques de compromission.

Dans ce contexte, ce projet consiste à concevoir, mettre en œuvre et sécuriser une petite infrastructure d'entreprise virtualisée. Il vise à appliquer des mesures de sécurité réseau et système, à contrôler les accès aux services, à renforcer les machines Linux et à vérifier l'efficacité des mesures à travers des tests techniques.

L'infrastructure est construite avec VMware et EVE-NG. pfSense assure le filtrage des communications entre les différentes zones réseau. Les systèmes Linux hébergent les services et les postes. Nmap est utilisé pour identifier les ports accessibles, tandis que Lynis permet d'auditer les configurations de sécurité.

Le projet intègre également un serveur Web hébergeant DVWA, une application volontairement vulnérable destinée aux tests applicatifs contrôlés. La détection et la supervision reposent sur Suricata, qui inspecte le trafic réseau, et Wazuh, qui centralise les événements de sécurité des machines surveillées.

Enfin, un dashboard intégrant des mécanismes d'intelligence artificielle et de machine learning vise à présenter les statistiques d'attaque par machine, les niveaux de sévérité et des recommandations de sécurité. Cette composante apporte une dimension analytique complémentaire aux mécanismes classiques de filtrage et de détection.

Le rapport est organisé en trois chapitres : la conception de l'infrastructure, son implémentation et son durcissement, puis les tests et l'évaluation des résultats.

Chapitre 1

Contexte, besoins et conception de l'infrastructure

1.1 Contexte et problématique

Une infrastructure d'entreprise doit permettre aux utilisateurs d'accéder aux ressources nécessaires à leur activité tout en limitant les communications non autorisées. Les serveurs accessibles depuis des réseaux moins fiables doivent être isolés des postes internes. Les interfaces d'administration doivent être réservées aux personnes autorisées, et les événements de sécurité doivent être collectés afin de faciliter l'investigation.

La problématique principale du projet est la suivante :

> **Comment concevoir et sécuriser une infrastructure réseau segmentée, renforcer les postes et les serveurs, détecter les activités suspectes et exploiter les événements collectés pour améliorer la visibilité sur les attaques ?**

Pour répondre à cette problématique, le projet combine la segmentation réseau, le filtrage, le durcissement des systèmes, les tests de sécurité, la détection des activités suspectes et leur visualisation dans un dashboard intelligent.

1.2 Objectifs du projet

Les objectifs sont les suivants :

- Concevoir une topologie réseau virtuelle représentative d'une petite entreprise.
- Définir un plan d'adressage IP cohérent.
- Séparer les réseaux WAN, LAN, DMZ et MGMT.
- Configurer les règles de filtrage du pare-feu.
- Sécuriser les services SSH et Web.
- Appliquer le principe du moindre privilège.
- Auditer et durcir les systèmes Linux.
- Comparer les résultats des tests avant et après les mesures de sécurité.

— Détecter les activités réseau suspectes avec Suricata.
— Centraliser les événements de sécurité avec Wazuh.
— Présenter les statistiques, les sévérités et les recommandations dans un dashboard IA/ML.
— Documenter les configurations et les résultats avec des preuves techniques.

1.3 Besoins fonctionnels et exigences de sécurité

Domaine	**Exigence**
Segmentation réseau	Séparer les postes utilisateurs, les serveurs exposés et l'administration
Filtrage	Contrôler les flux selon leur source, leur destination et leur service
Services	Limiter l'exposition aux ports nécessaires
SSH	Restreindre l'administration aux sources autorisées
Comptes	Appliquer le principe du moindre privilège
Durcissement	Réduire les services inutiles et corriger les configurations faibles
Détection	Identifier les activités réseau suspectes
Supervision	Centraliser les événements des machines surveillées
Analyse	Visualiser les attaques, leurs sévérités et les recommandations
Validation	Comparer les résultats des tests avant et après durcissement

Table 1.1 – Besoins fonctionnels et exigences de sécurité

1.4 Architecture générale

L'infrastructure est construite dans EVE-NG et exécutée dans un environnement virtualisé. pfSense constitue le point central de routage et de filtrage entre les différentes zones.

— **WAN :** réseau externe utilisé notamment pour les tests depuis Kali Linux.
— **LAN :** réseau du poste utilisateur Client-LAN.
— **DMZ :** zone hébergeant le serveur Web Debian et DVWA.
— **MGMT :** zone destinée à l'administration des machines et aux accès de supervision.
— **Suricata :** inspecte le trafic sur les interfaces où il est activé.
— **Wazuh :** centralise et analyse les événements provenant des agents configurés.
— **Dashboard IA/ML :** présente les statistiques d'attaque, les sévérités et les recommandations.

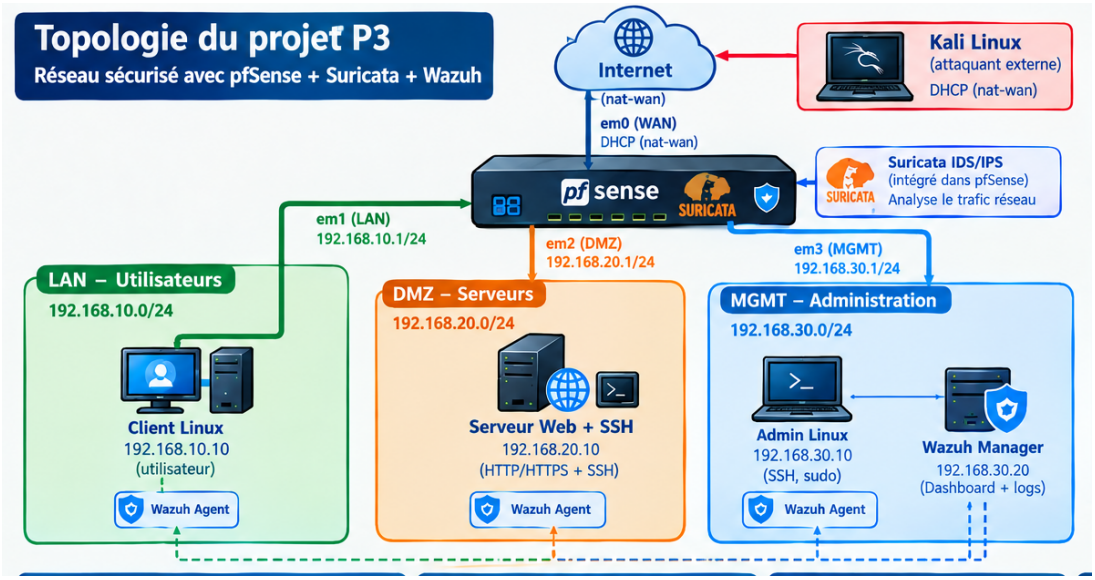


Figure 1.1 – Topologie générale de l'infrastructure EVE-NG

La figure met en évidence l'isolation logique des différentes zones et le rôle du pare-feu.

1.5 Plan d'adressage IP

Le plan d'adressage utilisé dans le laboratoire est présenté dans le tableau 1.2.

Équipement	Zone	Adresse IP
pfSense — WAN	WAN	192.168.99.129
pfSense — LAN	LAN	192.168.10.2
pfSense — DMZ	DMZ	192.168.20.2
pfSense — MGMT	MGMT	192.168.30.2
Kali Linux	WAN / réseau de test	192.168.99.133
Client-LAN	LAN	192.168.10.10
Serveur Web/DVWA	DMZ	192.168.20.10
Admin-MGMT	MGMT	192.168.30.10
Wazuh	Supervision / MGMT	192.168.30.20

Table 1.2 – Plan d'adressage IP du laboratoire

La séparation des sous-réseaux permet d'appliquer des politiques de sécurité différentes selon la fonction des machines.

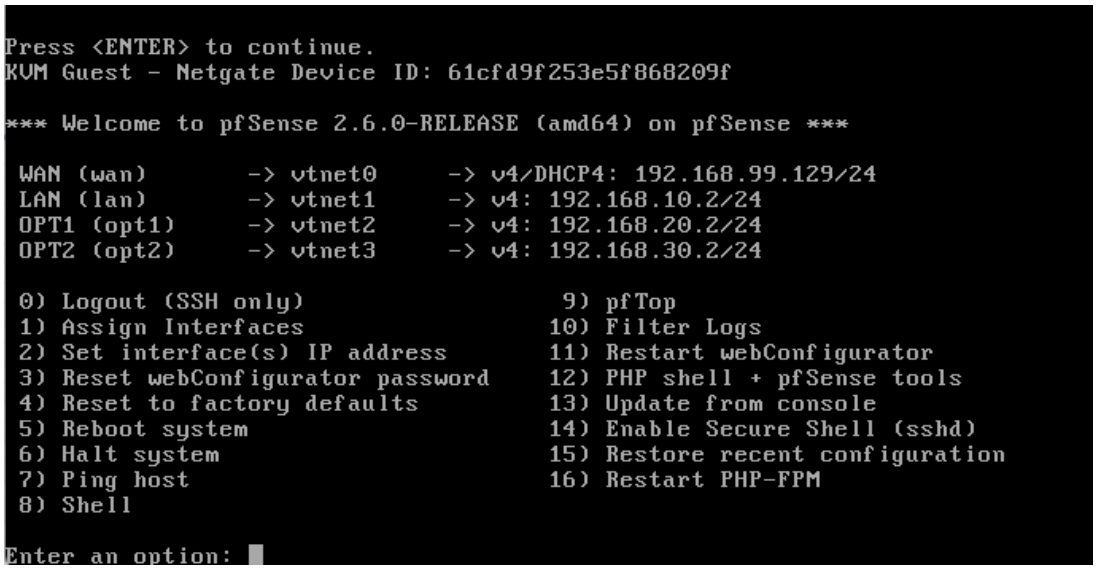


Figure 1.2 – Les interfaces pfsense

1.6 Justification des choix technologiques

Table 1.3 – Technologies utilisées et rôle de chacune

Technologie	**Rôle**
VMware	Hébergement de l'environnement virtualisé
EVE-NG	Création et interconnexion des équipements virtuels
pfSense	Routage, filtrage et segmentation réseau
Debian/Linux	Hébergement des services et postes
Kali Linux	Réalisation des tests de sécurité autorisés
Nmap	Analyse des ports et identification des services
Lynis	Audit de sécurité et recommandations de durcissement
Suricata	Inspection réseau et détection d'activités suspectes
Wazuh	Collecte et analyse des événements système
DVWA	Tests applicatifs dans un environnement contrôlé
Dashboard IA/ML	Synthèse des événements et recommandations

1.7 Conclusion

Ce premier chapitre a permis de présenter le contexte du projet, les problématiques liées à la sécurité d'une infrastructure réseau et les objectifs à atteindre. La conception proposée repose sur une architecture segmentée en plusieurs zones : WAN, LAN, DMZ et réseau de management. Cette organisation permet de séparer les postes utilisateurs, les serveurs accessibles depuis les autres réseaux et les équipements d'administration afin de limiter les risques de propagation d'une attaque

Chapitre 2

Implémentation et durcissement de l'infrastructure

2.1 Présentation et description de l'architecture réseau sous EVE-NG

L'infrastructure a été réalisée dans EVE-NG (Emulated Virtual Environment Next Generation), qui permet de simuler un environnement réseau composé de plusieurs machines virtuelles interconnectées. Cette approche facilite la mise en place d'une architecture segmentée et la réalisation de tests de sécurité sans intervenir sur un réseau de production.

L'environnement comprend un pare-feu pfSense, une machine Kali Linux utilisée pour les tests de sécurité, des machines Linux réparties dans différentes zones réseau et une plateforme de supervision basée sur Wazuh. Un capteur Suricata est également utilisé pour analyser le trafic et détecter les activités potentiellement malveillantes.

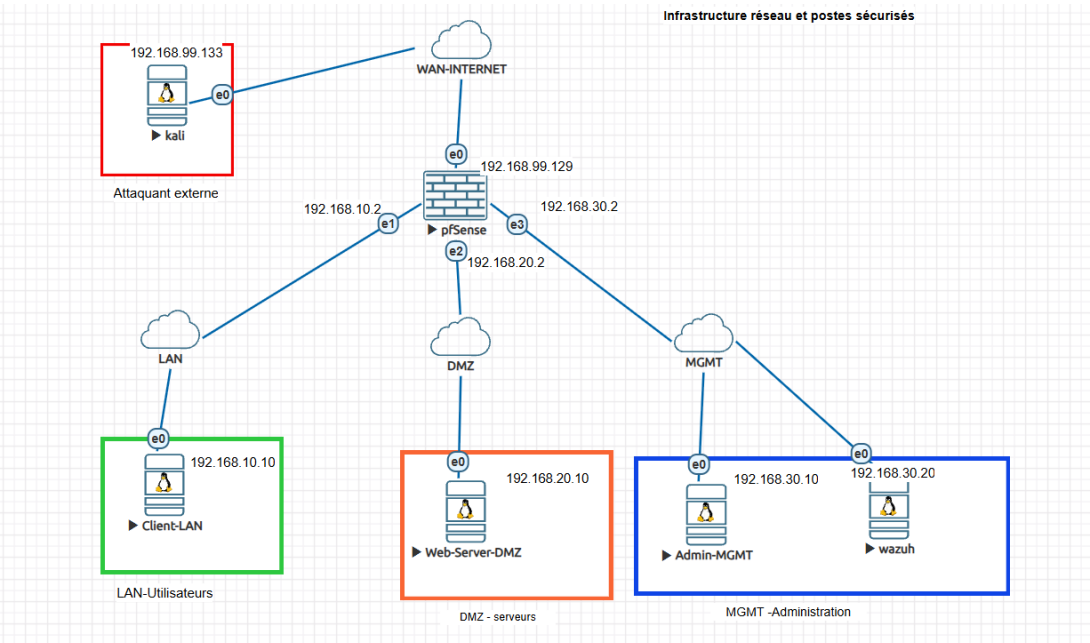


Figure 2.1 – Architecture EVE-NG

2.2 Configuration du pare-feu et segmentation réseau

pfSense assure le routage entre les différentes zones et applique les règles de filtrage. La politique de sécurité vise à refuser les communications non nécessaires et à autoriser uniquement les flux indispensables au fonctionnement de l'infrastructure.

La politique de filtrage attendue est présentée dans le tableau 2.1.

Source	**Destination**	**Service**	**Politique attendue**
Kali / WAN	Serveur Web DMZ	HTTP/HTTPS	Autoriser pour les tests contrôlés
Kali / WAN	Administration pfSense	HTTP/HTTPS d'administration	Refuser
Kali / WAN	Serveur DMZ	SSH	Refuser sauf autorisation spécifique
LAN	Internet	DNS, HTTP/HTTPS selon les besoins	Autoriser selon la politique définie
LAN	MGMT	Administration	Refuser par défaut
DMZ	LAN	Nouvelles connexions	Refuser par défaut
DMZ	MGMT	Administration	Refuser par défaut
Admin-MGMT	Serveurs administrés	SSH et services nécessaires	Autoriser de manière ciblée
Machines surveillées	Wazuh	Communications des agents	Autoriser selon la configuration
Sources autorisées	Services de supervision	Ports nécessaires	Autoriser de manière ciblée

Table 2.1 – Politique de filtrage attendue

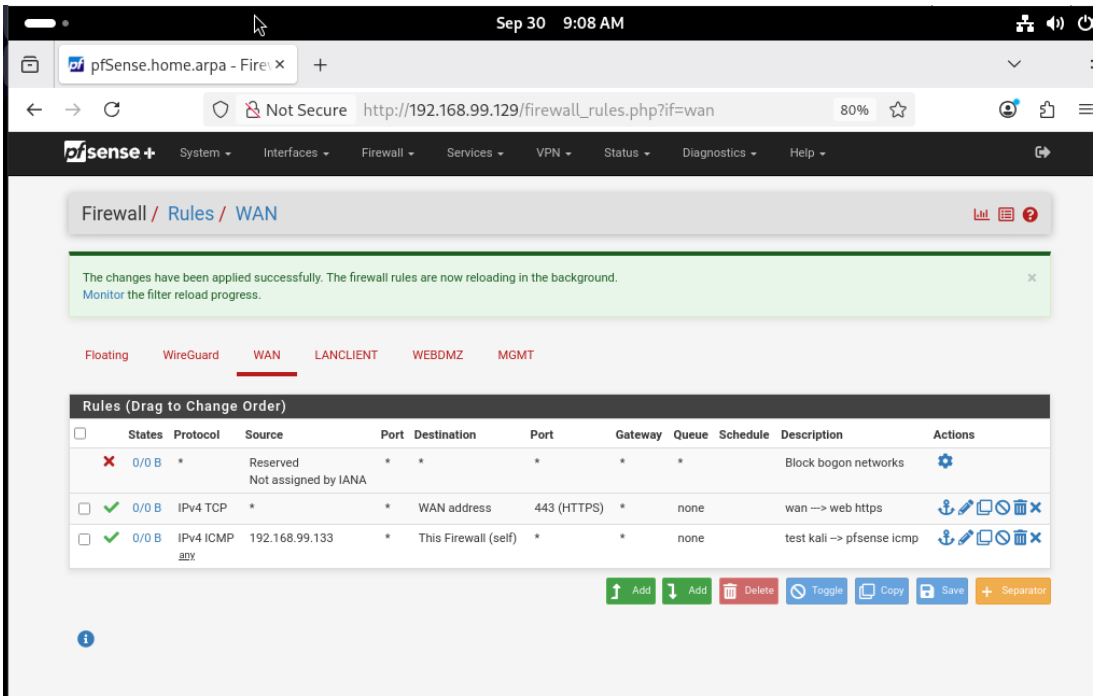


FIGURE 2.2 – Regles filtrage WAN

L'interface WAN assure le contrôle des communications provenant du réseau externe. Les règles configurées bloquent les adresses réservées ou non valides (*bogon networks*), autorisent le trafic HTTPS vers l'adresse WAN de pfSense et permettent à Kali Linux d'effectuer des tests de connectivité ICMP vers le pare-feu. Ces règles contribuent à contrôler l'exposition du pare-feu, mais l'accès HTTPS doit être limité aux sources autorisées lorsqu'il sert à l'administration.

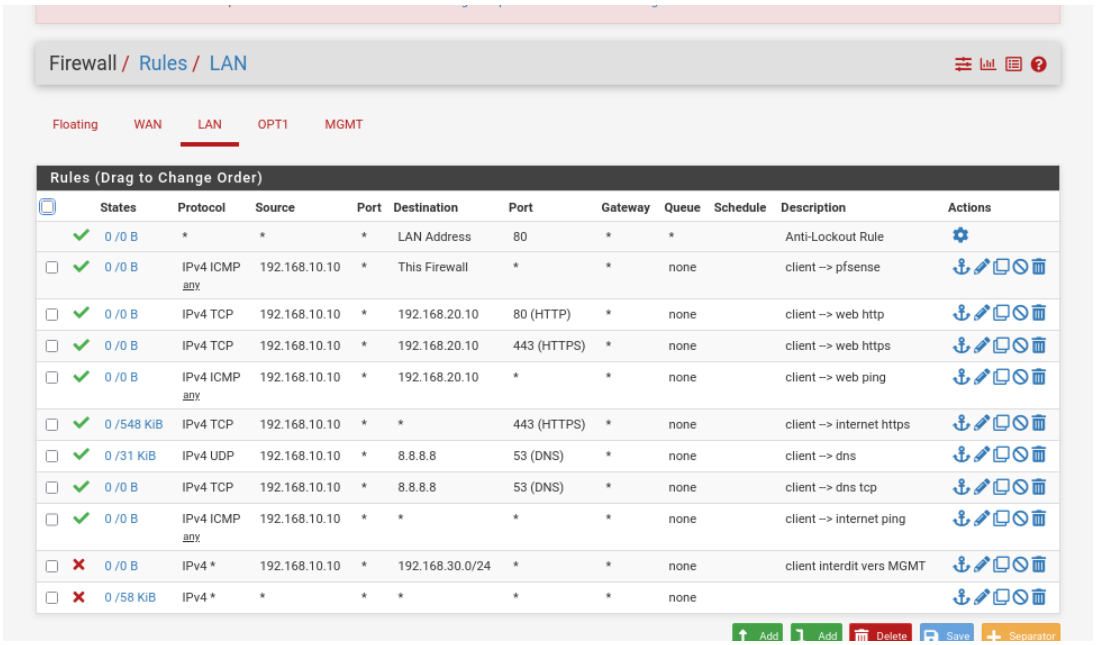


FIGURE 2.3 – Regles de filtrage client lan

L'interface LAN permet au client Debian d'accéder aux services nécessaires : serveur Web

de la DMZ via HTTP/HTTPS, Internet via HTTPS et résolution DNS via '8.8.8.8'. Des règles ICMP facilitent les tests de connectivité avec pfSense, le serveur Web et Internet. Une règle spécifique vise à bloquer l'accès au réseau MGMT, tandis que la règle finale bloque les autres communications non autorisées. Cette politique cherche à assurer le fonctionnement du client tout en protégeant le réseau d'administration.

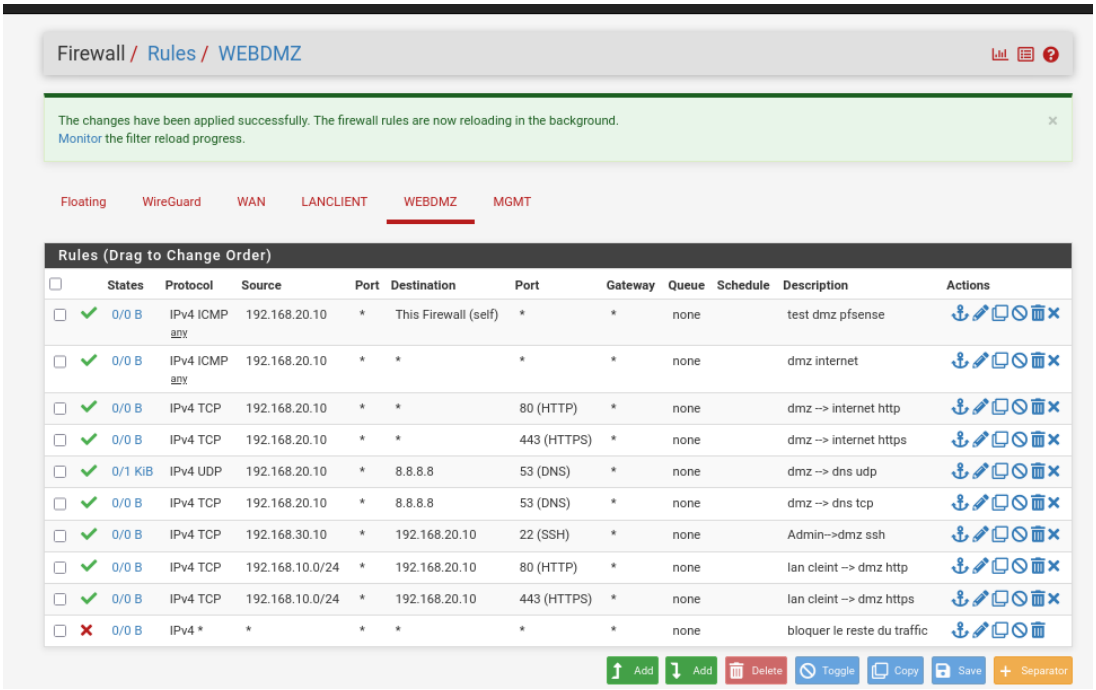


FIGURE 2.4 – regles filtrage DMZ

L'interface DMZ encadre les communications du serveur Web . Les règles autorisent les tests ICMP, l'accès DNS et les connexions HTTP/HTTPS sortantes nécessaires. Le poste d'administration est autorisé à accéder au serveur en SSH, tandis que le LAN peut accéder à ses services Web via HTTP/HTTPS. Une règle finale vise à bloquer le trafic restant.

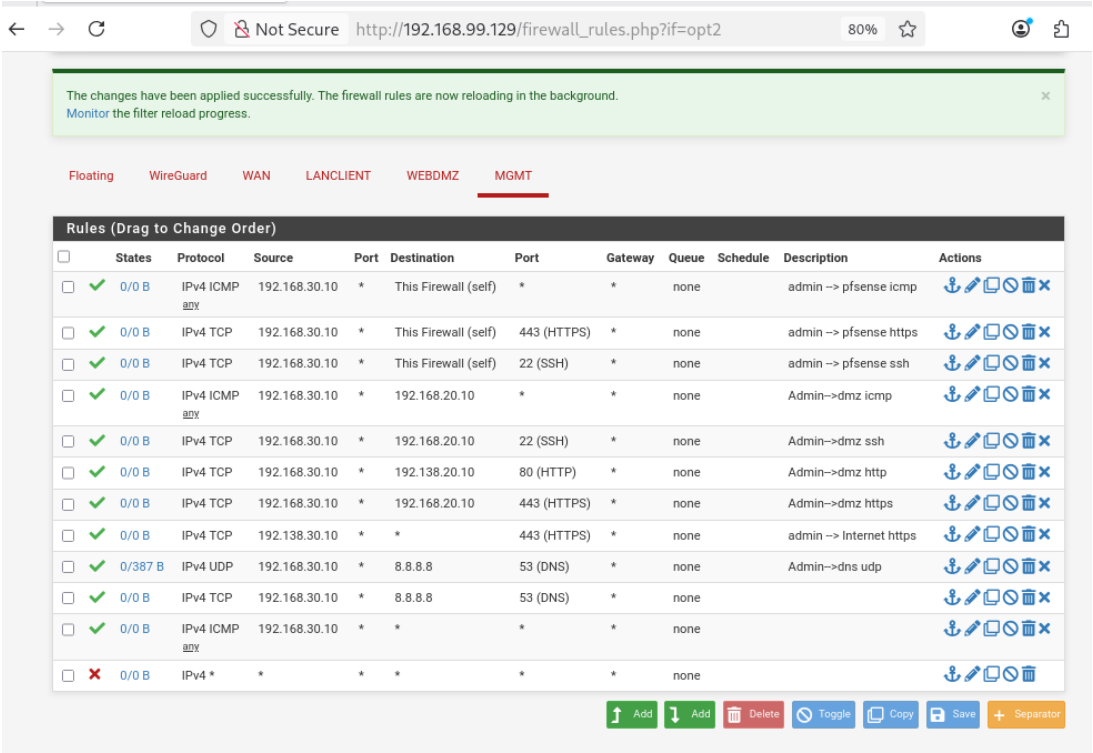


FIGURE 2.5 – regles filtrage MGMT

L'interface MGMT est dédiée à l'administration de l'infrastructure depuis le poste '192.168.30.10'. Les règles permettent de tester la connectivité avec pfSense, d'accéder à son interface Web en HTTPS et, si nécessaire, à son service SSH. Elles autorisent également l'administration du serveur DMZ via SSH et l'accès à ses services Web. Des règles permettent la navigation HTTPS et la résolution DNS. Enfin, une règle de blocage vise à interdire les autres communications non autorisées. Cette politique doit préserver l'isolement du réseau de management et réserver les accès aux seuls équipements autorisés.

2.3 Mise en place du serveur Web et de DVWA

Le serveur Web Debian est déployé dans la DMZ à l'adresse `192.168.20.10`. Apache fournit le service Web, tandis que DVWA est utilisée pour réaliser des tests applicatifs dans un environnement volontairement vulnérable.

L'application est accessible par le chemin :

`http://192.168.20.10/dvwa/`

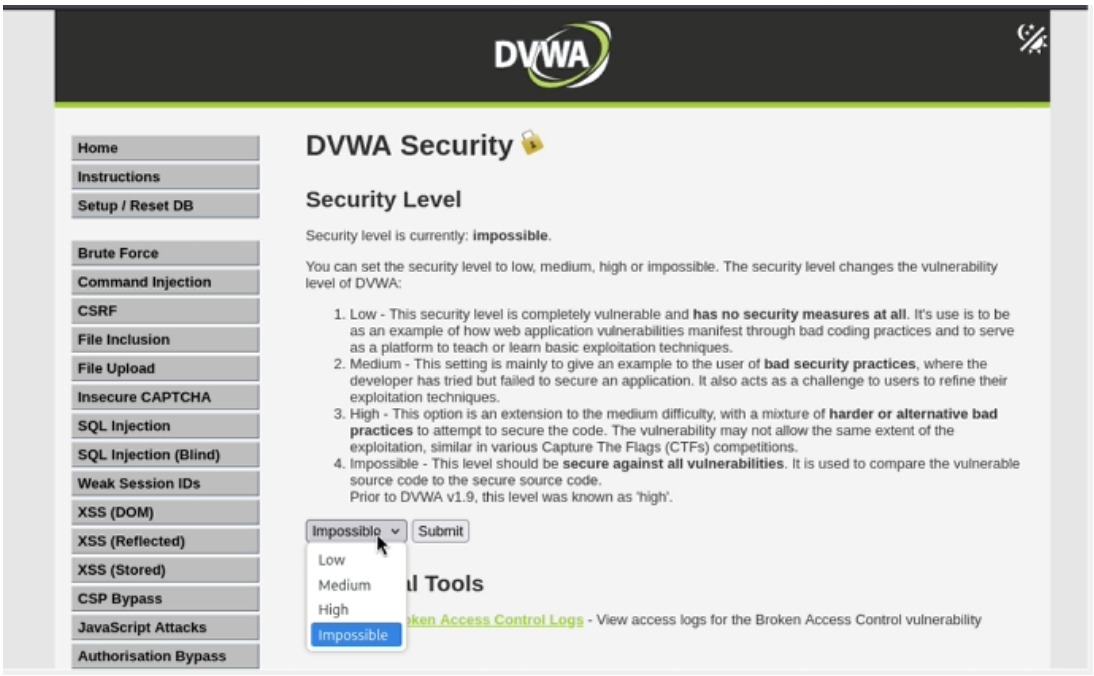


Figure 2.6 – page de connexion DVWA

2.4 Sécurisation de SSH et gestion des privilèges

SSH permet l'administration des systèmes Linux. Son accès doit être limité aux sources autorisées, de préférence au réseau MGMT.

Les mesures de sécurité comprennent :

— Limitation de l'accès SSH par les règles réseau et le pare-feu local.
— Contrôle de la connexion directe de root.
— Limitation des tentatives d'authentification.
— Utilisation de comptes individuels.
— Préférence pour l'authentification par clé lorsque celle-ci est correctement configurée.
— Contrôle des groupes administratifs et des permissions.
— Vérification des journaux d'authentification.

Les commandes suivantes permettent de contrôler certains paramètres :

```
root@dmz:~# sudo sshd -T | grep -E '^(port|permitrootlogin|passwordauthentication|pubkeya
uthentication|x11forwarding|maxauthtries)'
port 22
maxauthtries 6
permitrootlogin without-password
pubkeyauthentication yes
passwordauthentication yes
x11forwarding yes
root@dmz:~#
```

Figure 2.7 – Paramètres effectifs de SSH

2.5 Rapport de durcissement des systèmes Linux

2.5.1 Objectif et périmètre

Le durcissement des systèmes Linux vise à réduire la surface d'attaque, à corriger les configurations insuffisamment sécurisées et à limiter les services et les privilèges aux besoins réels de chaque machine. Cette étape complète la segmentation réseau réalisée avec pfSense en ajoutant des mécanismes de protection directement sur les hôtes.

Les systèmes concernés sont le serveur Web de la DMZ, identifié par l'adresse 192.168.20.10, et le poste Client-LAN, configuré avec l'adresse 192.168.10.10. Les contrôles doivent être réalisés séparément, car ces deux machines n'assurent pas les mêmes fonctions et ne nécessitent donc pas les mêmes services.

La démarche de durcissement repose sur plusieurs étapes : réalisation d'un audit initial, identification des faiblesses, application des mesures correctives, vérification de la configuration après modification et comparaison des résultats. Les outils utilisés comprennent notamment Lynis pour l'audit de sécurité, les commandes système pour l'inspection des services et des comptes, ainsi que Nmap pour vérifier l'exposition réseau.

2.5.2 État initial observé

Un audit de sécurité a été réalisé sur un système Debian à l'aide de Lynis 3.1.4. Les informations disponibles font état de scores de durcissement de 60. Cette valeur doit être rattachée à son rapport afin d'identifier le système concerné, la date de l'audit et les éventuelles différences de configuration. .

Lors d'un scan Nmap antérieur du serveur Web 192.168.20.10, les ports TCP/22, TCP/80 et TCP/443 ont été observés ouverts. Ils correspondent respectivement aux services SSH, HTTP et HTTPS. Cette observation constitue un état de référence pour évaluer l'exposition du serveur et vérifier ensuite les effets du durcissement.

La présence de ces ports n'indique pas nécessairement une vulnérabilité. Cependant, chaque service doit être justifié par le rôle du serveur, et son accès doit être limité aux sources autorisées. Le port SSH doit notamment être réservé à l'administration, tandis que les ports Web doivent correspondre aux services effectivement utilisés.

```
root@dmz:~# lynis audit system --no-colors

[ Lynis 3.1.4 ]

################################################################################
  Lynis comes with ABSOLUTELY NO WARRANTY. This is free software, and you are
  welcome to redistribute it under the terms of the GNU General Public License.
  See the LICENSE file for details about using this software.

  2007-2024, CISOfy - https://cisofy.com/lynis/
  Enterprise support available (compliance, plugins, interface and tools)
################################################################################


[+] Initializing program
------------------------------------
  - Detecting OS...                                           [ DONE ]
  - Checking profiles...                                      [ DONE ]

  ---------------------------------------------------
  Program version:           3.1.4
  Operating system:          Linux
  Operating system name:     Debian
  Operating system version:  13
  Kernel version:            6.12.111+deb13
  Hardware platform:         x86_64
  Hostname:                  dmz
  ---------------------------------------------------
  Profiles:                  /etc/lynis/default.prf
  Log file:                  /var/log/lynis.log
  Report file:               /var/log/lynis-report.dat
  Report version:            1.0
  Plugin directory:          /etc/lynis/plugins
  ---------------------------------------------------
  Auditor:                   [Not Specified]
```

Figure 2.8 – Résultat initial de Lynis

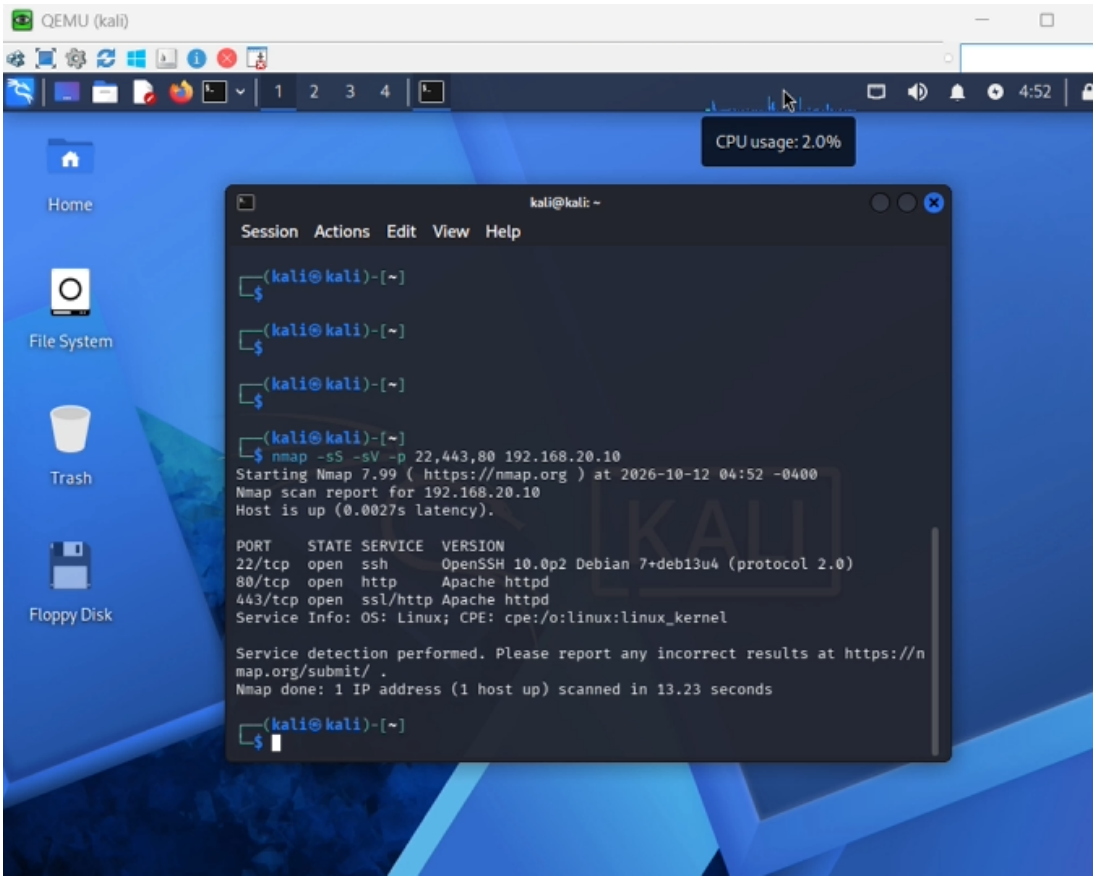


Figure 2.9 – Scan Nmap initial

2.5.3 Mise à jour du système

La mise à jour du système constitue une mesure essentielle du durcissement. Elle permet d'installer les correctifs de sécurité disponibles et de réduire l'exposition aux vulnérabilités connues affectant le noyau, les bibliothèques et les services installés.

Sur les systèmes Debian, la vérification des mises à jour peut être réalisée avec les commandes suivantes :

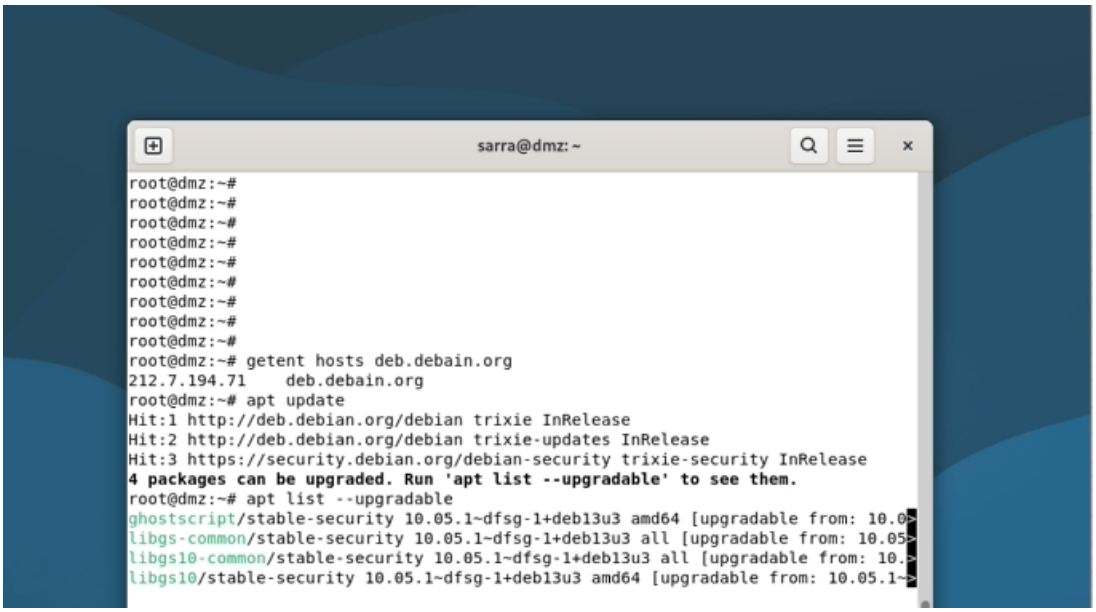


Figure 2.10 – verification des mises a jour

Après vérification, les paquets peuvent être mis à niveau en tenant compte des dépendances et de l'impact éventuel sur les services . Une vérification du fonctionnement d'Apache, de SSH et de l'agent Wazuh doit être effectuée après les modifications.

2.5.4 Inventaire et réduction des services

L'inventaire des services permet d'identifier les applications actives, les ports en écoute et les composants qui augmentent la surface d'attaque. Cette vérification doit être réalisée sur le serveur DMZ et le poste Client-LAN, puis comparée aux besoins de chaque système.

Sur le serveur Web, Apache est nécessaire à l'hébergement de l'application Web et de DVWA. SSH peut également être conservé pour l'administration, à condition que son accès soit limité au poste d'administration 192.168.30.10. Les autres services doivent être examinés individuellement avant toute désactivation, afin d'éviter de perturber le fonctionnement du système ou la collecte des événements de sécurité.

2.5.5 Installation des outils de sécurité complémentaires

Afin de renforcer la protection du serveur, plusieurs outils complémentaires ont été retenus. Leur installation doit être effectuée après confirmation du bon fonctionnement d'APT.

La commande prévue est la suivante :

sudo apt install fail2ban libpam-tmpdir apt-listbugs -y

Les outils sélectionnés remplissent des fonctions différentes :

Fail2ban : analyse certains journaux afin d'identifier des comportements tels que des tentatives répétées d'authentification échouées. Lorsqu'il est correctement configuré, il peut appliquer des blocages temporaires aux adresses IP concernées. Son efficacité dépend des filtres, des journaux surveillés et de l'action de bannissement configurée.

libpam-tmpdir : fournit un module PAM destiné à améliorer l'isolation des répertoires temporaires des utilisateurs, selon la configuration du système.

apt-listbugs : signale les bogues connus, notamment ceux classés critiques, associés aux paquets Debian avant certaines opérations d'installation ou de mise à niveau. Il complète la vérification des mises à jour, sans remplacer l'analyse des vulnérabilités.

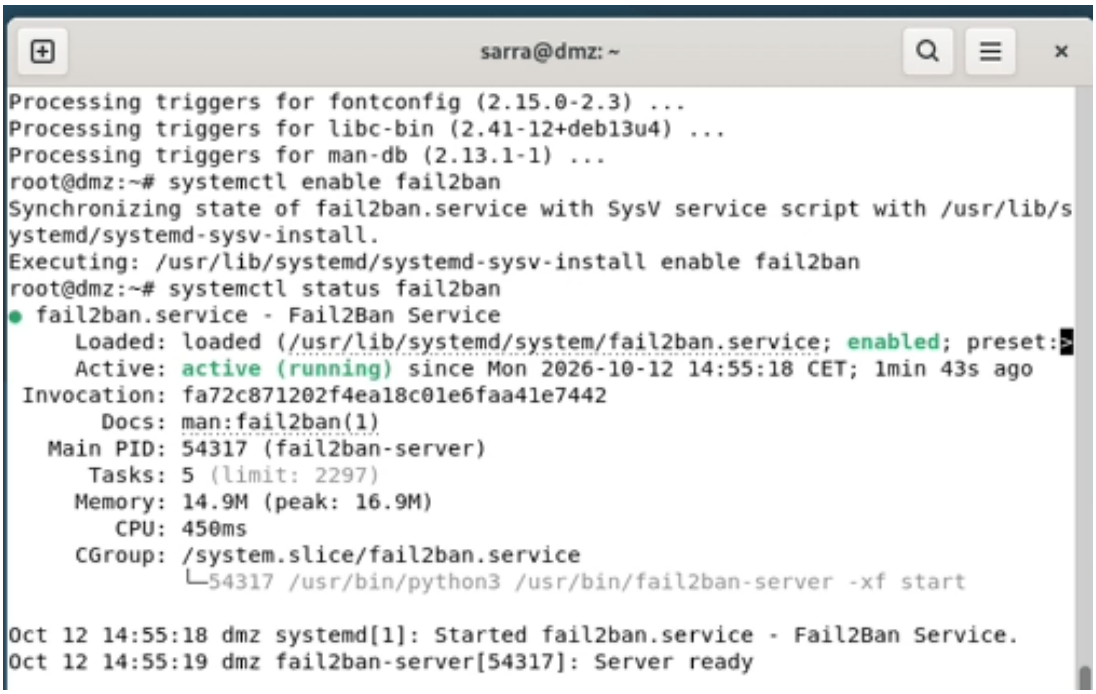


Figure 2.11 – Installation et vérification des outils de sécurité

2.5.6 2.4.5 Renforcement du serveur Web Apache

LLe serveur Web de la DMZ héberge les services HTTP/HTTPS et l'application DVWA utilisée pour les tests de sécurité. En raison de son exposition réseau, Apache constitue un composant important à protéger.



Figure 2.12 – politique serveur ssh

Lors d'une vérification antérieure du poste DMZ , le paramètre PermitRootLogin without-password et la valeur MaxAuthTries 6 avaient été observés. La première valeur permet certaines formes d'authentification directe de root sans mot de passe, notamment par clé, selon la configuration effective. La seconde limite le nombre de tentatives d'authentification par connexion, mais peut être ajustée selon les besoins.

Pour renforcer cette configuration, il est recommandé de :

Désactiver la connexion SSH directe de root avec PermitRootLogin no, si l'administration par un compte nominatif disposant de sudo est possible.

Privilégier l'authentification par clés SSH et désactiver l'authentification par mot de passe uniquement après avoir vérifié le bon fonctionnement de l'accès par clé.

Limiter les utilisateurs autorisés au moyen de AllowUsers ou d'un groupe dédié.

Désactiver le transfert X11 et les redirections SSH lorsqu'ils ne sont pas nécessaires.

Restreindre le port TCP/22 dans pfSense aux sources d'administration autorisées.

2.5.7 Audit final avec Lynis

Après application des mesures, Lynis doit être relancé sur chaque système concerné.

Commande :

```
sudo lynis audit system
```

Le rapport final doit être comparé au rapport initial. Les avertissements doivent être examinés individuellement et les améliorations documentées.

Un score plus élevé peut indiquer une amélioration de certains contrôles, mais il ne garantit pas à lui seul que le système est sécurisé. L'évaluation doit aussi prendre en compte les ports exposés, les privilèges, les services, les journaux et les tests réseau.

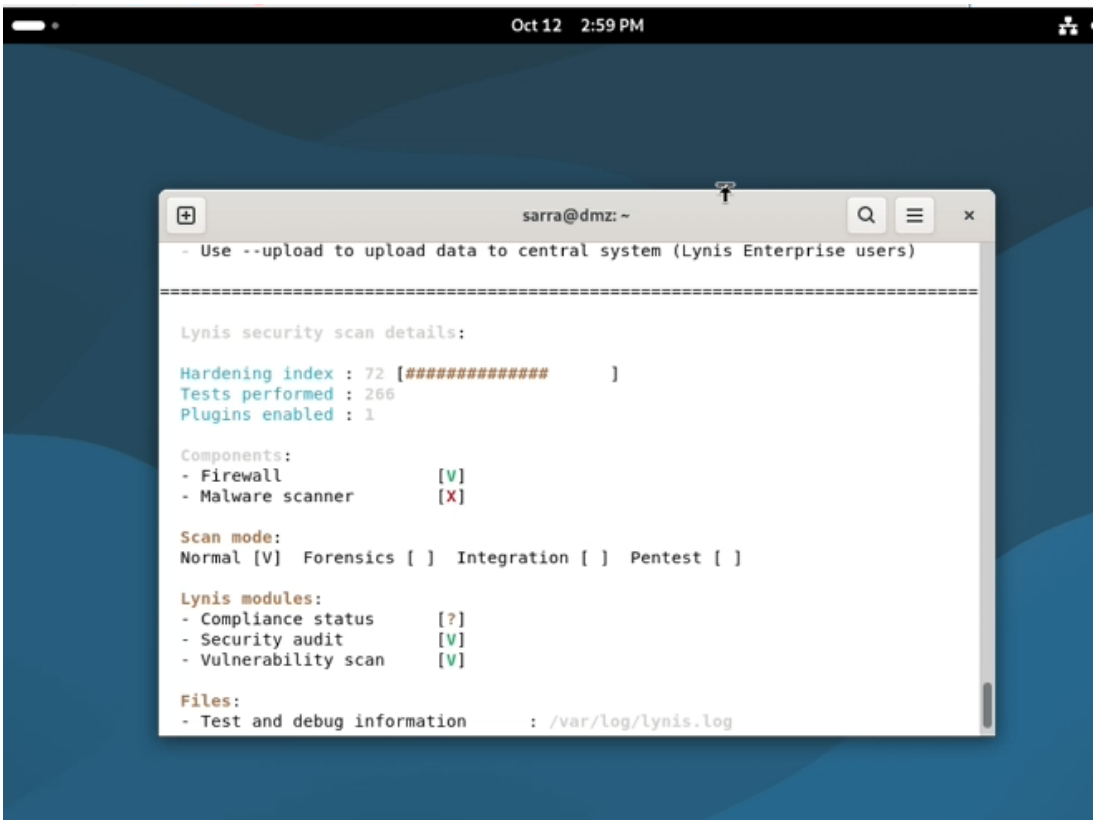


Figure 2.13 – Résultat final de Lynis

2.5.8 Tableau de synthèse du durcissement

Table 2.2 – Synthèse du durcissement

Contrôle	État initial disponible	État final à documenter
Audit Lynis	Score 72 observé lors d'un audit antérieur	Insérer le score réellement obtenu
Services	Inventaire initial à joindre	Services nécessaires vérifiés
Ports Web/SSH	Ports 22, 80 et 443 observés ouverts lors d'un scan	Résultat Nmap final à joindre
SSH	Configuration initiale partiellement examinée	Paramètres effectifs après modification
Pare-feu local	État initial à documenter	Règles et état final à joindre
Comptes et privilèges	Inventaire initial à documenter	Droits revus et justifiés
Paquets	État initial à documenter	Mise à jour et vérification finales
Journaux	Collecte à vérifier	Journaux disponibles et exploitables
Wazuh	Agents et remontée des événements à contrôler	Événements reçus après les tests

Ce tableau doit être complété à partir des résultats réels. Il ne faut pas annoncer un score final, une fermeture de port ou une amélioration si la vérification correspondante n'a pas été effectuée.

2.6 Détection réseau avec Suricata

Suricata inspecte le trafic sur les interfaces où il est activé et recherche les activités correspondant aux règles de détection chargées.

Il complète le filtrage de pfSense : le pare-feu contrôle les flux autorisés, tandis que Suricata peut identifier certains comportements suspects dans le trafic inspecté.

Les tests de reconnaissance depuis Kali permettent de générer un trafic contrôlé et de vérifier si des alertes correspondantes sont produites. La validation doit porter sur les interfaces surveillées, l'état du moteur, les règles actives et les journaux d'alerte.

L'absence d'alerte ne prouve pas l'absence d'activité suspecte : le trafic peut ne pas traverser l'interface surveillée ou ne correspondre à aucune règle active.

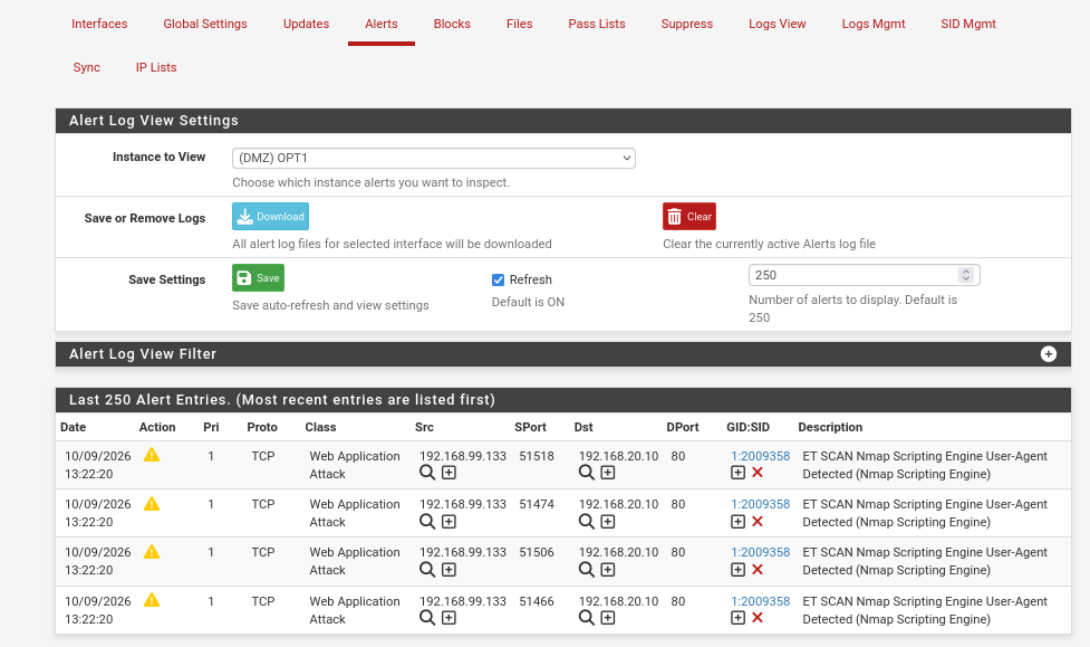


FIGURE 2.14 – Exemple d'alerte Suricata

2.7 Supervision et centralisation avec Wazuh

Wazuh centralise les événements des machines disposant d'agents correctement installés et configurés. Les événements collectés peuvent concerner les connexions, les journaux système, les services et les accès Web.

Pendant les tests précédents, des événements liés au serveur Web ont été observés dans Wazuh, notamment des traces associées à la reconnaissance Nmap et une alerte Web.

Ces observations montrent que certaines activités de test ont été visibles dans la super-

vision. Elles ne signifient pas que toutes les attaques applicatives produisent automatiquement une alerte dédiée. La détection dépend des journaux collectés et des règles disponibles.

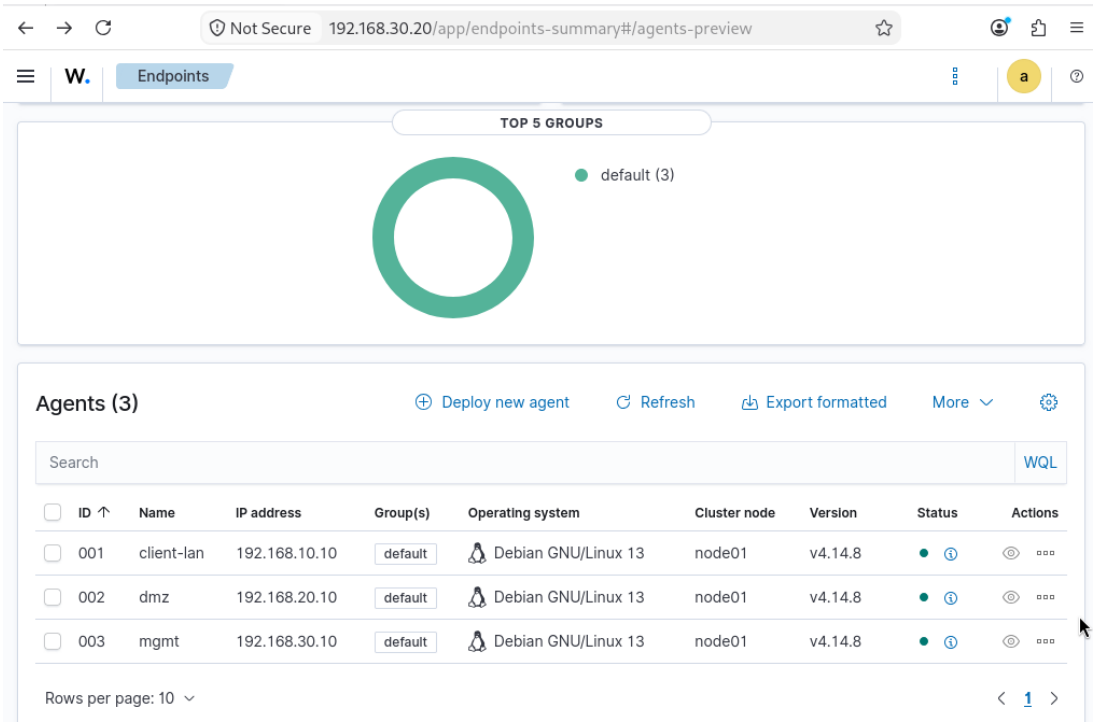


FIGURE 2.15 – etat des agents wazuh

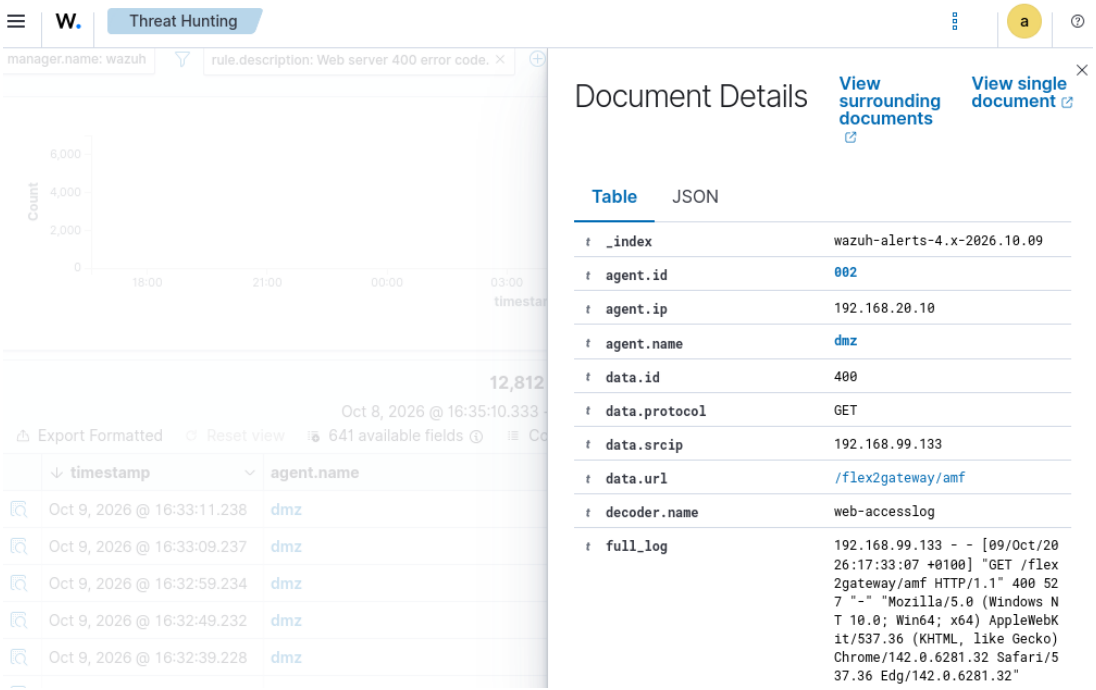


FIGURE 2.16 – Exemple d'alerte Wazuh sur dmz

2.8 Dashboard intelligent basé sur l'IA

Le dashboard constitue la couche de visualisation et d'analyse du projet. Il vise à transformer les événements de sécurité en informations plus faciles à interpréter.

Les indicateurs attendus comprennent :

— Le nombre d'événements par machine.
— La répartition des alertes par niveau de sévérité.
— Les types d'activités détectées.
— L'évolution temporelle du volume d'alertes.
— Les machines les plus concernées par les événements.
— Les recommandations associées aux alertes ou aux constats de sécurité.

La description du composant IA/ML doit correspondre à l'implémentation réelle. Si un modèle de machine learning est intégré, le rapport doit préciser son type, les données d'entrée, les variables utilisées et la méthode d'évaluation. Si les recommandations proviennent de règles prédéfinies ou d'un modèle de langage, cette méthode doit être distinguée du modèle de classification ou de détection d'anomalies.

Le dashboard doit permettre de distinguer une alerte observée, une classification calculée et une recommandation générée. Une recommandation automatique constitue une aide à l'analyse et ne prouve pas qu'une attaque a réussi.

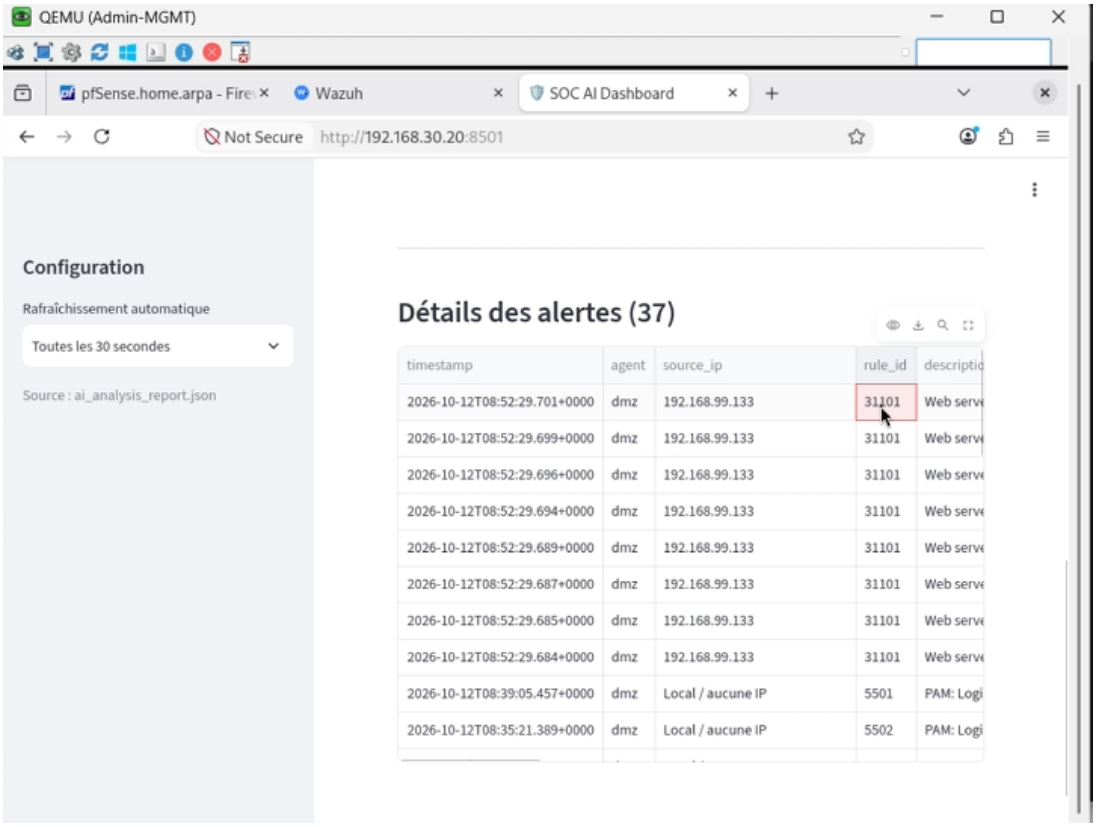


Figure 2.17 – Vue générale du dashboard IA

2.9 Conclusion

Conclusion

Ce chapitre a présenté la mise en œuvre des mécanismes de sécurité de l'infrastructure, depuis le filtrage des communications avec pfSense jusqu'au durcissement des systèmes Linux et à la supervision des événements. La segmentation réseau permet de différencier les flux du LAN, de la DMZ et du réseau de management, tandis que les mesures de durcissement visent à réduire la surface d'attaque, à limiter les privilèges et à maîtriser les services exposés.

L'intégration de Suricata et de Wazuh apporte une capacité complémentaire de détection et de centralisation des événements. L'analyse réalisée avec Lynis et les vérifications des ports et des services fournissent également une base pour identifier les points à améliorer. Toutefois, l'efficacité de ces mécanismes dépend de la validation effective des règles, de la configuration des hôtes et de la qualité des journaux collectés. Le chapitre suivant sera donc consacré aux tests de sécurité, à l'analyse des résultats et à la vérification de l'efficacité des mesures mises en place.

Chapitre 3

Tests, résultats et évaluation de la sécurité

3.1 Méthodologie de validation

La validation consiste à mesurer le comportement de l'infrastructure avant et après l'application des mesures de sécurité.

La démarche comprend :

1. Relever l'état initial des systèmes.
2. Identifier les ports accessibles avec Nmap.
3. Vérifier les communications entre les zones.
4. Appliquer les mesures de filtrage et de durcissement.
5. Répéter les mêmes tests dans des conditions comparables.
6. Examiner les alertes Suricata et Wazuh.
7. Comparer les résultats et documenter les écarts.
8. Vérifier que le dashboard présente des données cohérentes avec les événements sources.

Les tests sont réalisés dans le laboratoire contrôlé et sur les machines autorisées.

3.2 Tests Nmap avant et après durcissement

La commande suivante permet d'examiner les ports TCP/22, TCP/80 et TCP/443 du serveur Web de la DMZ :

```
nmap -sS -sV -p 22,80,443 192.168.20.10
```

Lors d'un essai précédent, les trois ports ont été observés ouverts. Cette observation constitue un état de référence pour l'analyse de l'exposition du serveur.

Après durcissement, le scan doit être répété depuis la même machine source et avec les mêmes paramètres. Le résultat doit être interprété en fonction des règles appliquées et des services attendus.

Les états Nmap ont les significations suivantes :

— `open` : un service accepte les connexions sur le port.
— `closed` : la cible répond, mais aucun service n'écoute sur le port.
— `filtered` : le filtrage ou l'absence de réponse empêche Nmap de déterminer l'état du port.

Le passage d'un port à l'état `filtered` ne prouve pas à lui seul que le serveur est mieux sécurisé. Il faut vérifier que le service reste accessible aux sources autorisées et que les sources non autorisées sont bloquées.

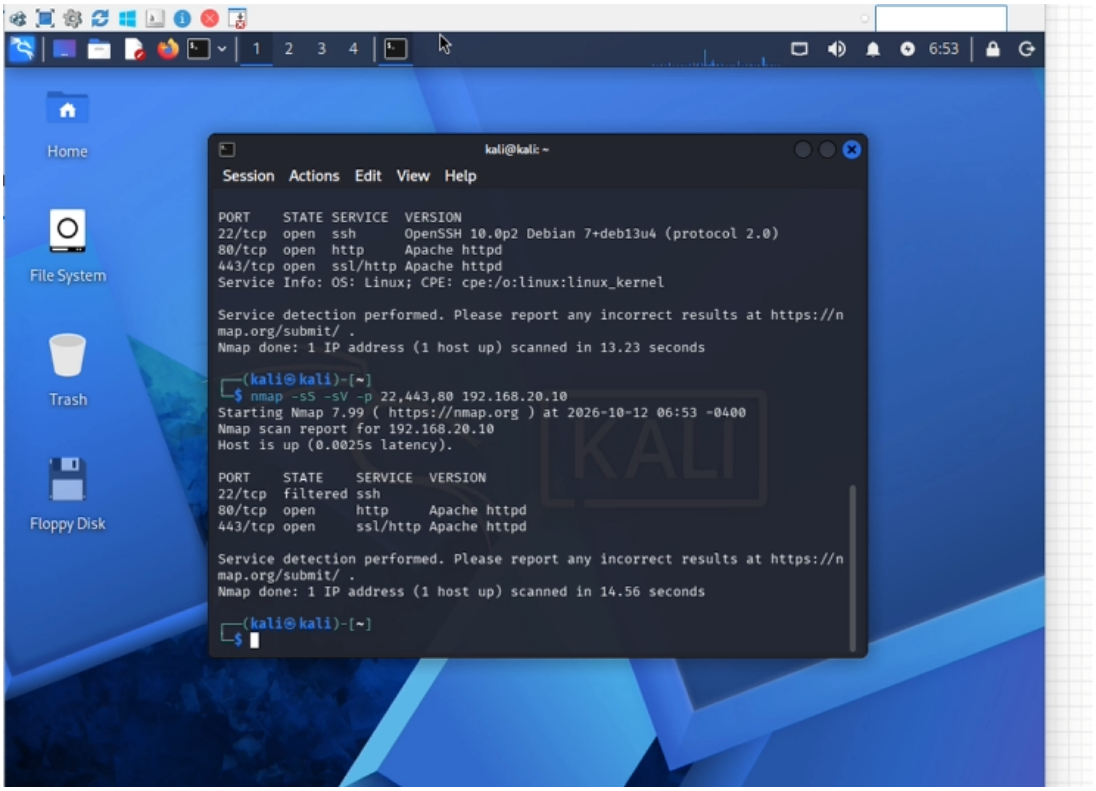


Figure 3.1 – Scan nmap apres durcissement

3.3 Tests applicatifs avec DVWA

DVWA permet de réaliser des tests applicatifs contrôlés, notamment la reconnaissance de l'application, le XSS réfléchi, l'injection SQL et la command injection, selon les fonctionnalités disponibles et le niveau de sécurité sélectionné.

Pour chaque essai, il faut enregistrer le type de test, le niveau DVWA, la cible, le résultat visible dans le navigateur et les traces disponibles dans Apache, Suricata et Wazuh.

Une attaque visible dans le navigateur ne signifie pas nécessairement qu'une alerte dédiée sera générée dans Wazuh. Le contenu de certaines requêtes, notamment les données POST, peut ne pas apparaître dans les journaux d'accès standard.



Figure 3.2 – SQL Injection sur DVWA depuis kali

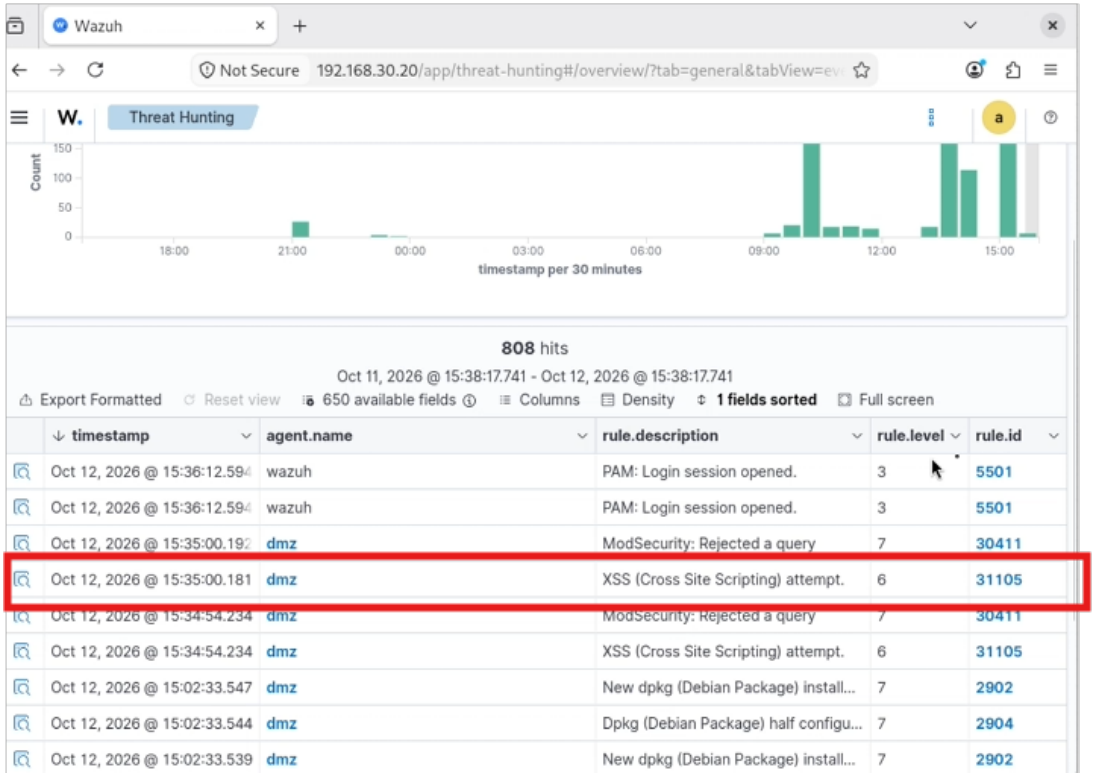


Figure 3.3 – Alerte de sécurité correspondante

3.4 Résultats du durcissement

Le tableau **??** rassemble les principales observations disponibles et les mesures nécessaires pour terminer l'évaluation.

Test	**Résultat disponible**	**Validation finale**
Scan du serveur DMZ	Ports 22, 80 et 443 observés ouverts lors d'un essai antérieur	Joindre le scan final
Accès à DVWA	Réponse HTTP 302 observée vers la connexion	Vérifier le comportement après durcissement
Audit Lynis	Score 72 observé lors d'un audit antérieur	Relancer l'audit et comparer
SSH	Paramètres partiellement examinés	Joindre la configuration effective finale
Pare-feu local	Configuration à documenter selon chaque machine	Vérifier les règles et les accès
Suricata	Configuration et alertes à documenter	Joindre les alertes correspondant aux tests
Wazuh	Événements Web et alerte de règle 31101 observés	Joindre les alertes finales pertinentes
Dashboard IA	Interface prévue pour les statistiques et recommandations	Vérifier la cohérence avec les événements sources

Table 3.1 – Résultats du durcissement et validations restantes

Cette synthèse distingue les observations déjà disponibles des validations encore nécessaires. Elle évite de présenter des améliorations non mesurées.

3.5 Évaluation du durcissement de l'infrastructure

L'évaluation du durcissement vise à déterminer si les mesures de sécurité appliquées aux systèmes et aux équipements réseau permettent de réduire les risques identifiés. Elle s'appuie sur l'examen des configurations effectives, les résultats des tests réalisés et les journaux produits par les outils de supervision.

3.5.1 Sécurisation des systèmes Linux

L'évaluation porte sur les mises à jour du système, la réduction des services inutiles, la justification des ports ouverts, la gestion des comptes et des privilèges, ainsi que le renforcement des accès SSH. Les résultats des audits Lynis permettent de compléter cette analyse en identifiant les paramètres nécessitant une amélioration.

3.5.2 Contrôle des communications réseau

Les règles de filtrage et les mécanismes de protection locaux sont examinés afin de vérifier que les services accessibles correspondent au rôle de chaque machine. Les scans Nmap et les tests de connectivité permettent de comparer le comportement observé aux exigences de sécurité définies.

3.5.3 Supervision et traçabilité

La disponibilité des journaux système et Web, le fonctionnement de l'agent Wazuh et la génération d'alertes par Suricata sont examinés à partir d'événements réels. L'objectif est de vérifier que les activités réalisées pendant les tests peuvent être observées et analysées à partir des traces disponibles.

3.6 Limites et perspectives

La topologie permet d'expérimenter les mécanismes de segmentation, de durcissement et de supervision. Cependant, la qualité de la détection dépend des interfaces surveillées, des journaux collectés et des règles activées.

Le dashboard IA doit également être évalué en fonction de son implémentation réelle. Si un modèle de machine learning est utilisé, ses performances doivent être mesurées avec des données et des métriques adaptées. Les données simulées doivent être clairement distinguées des événements réellement collectés.

L'ajout d'un second pfSense pour assurer la haute disponibilité peut constituer une évolution future. Cette fonctionnalité nécessiterait la configuration et la validation des interfaces partagées, des adresses virtuelles CARP et de la synchronisation d'état pfsync.

3.7 Conclusion

Les tests réalisés permettent d'évaluer le comportement de l'infrastructure face aux communications autorisées et aux tentatives d'accès non autorisées. Les scans Nmap permettent d'identifier les ports exposés, tandis que les vérifications de segmentation servent à confirmer que les communications entre le réseau externe, le LAN, la DMZ et le réseau de management respectent la politique de sécurité définie. Les contrôles de durcissement et les audits Lynis complètent cette validation en mettant en évidence les paramètres renforcés et les points qui nécessitent encore une amélioration.

La supervision par Suricata et Wazuh permet de rapprocher les activités observées sur le réseau des événements enregistrés sur les hôtes. Ces données constituent également une base pour la composante d'analyse intelligente du projet, destinée à faciliter la corrélation des alertes, l'évaluation du risque et la proposition de réponses défensives adaptées.

3.7.1 Cohérence de l'analyse intelligente

Le dashboard IA est évalué en comparant les informations affichées aux événements sources. Les statistiques, les niveaux de risque et les recommandations sont examinés uniquement lorsqu'ils sont effectivement implémentés. Cette vérification permet de distinguer les résultats issus des événements réels des données de test ou des éléments encore en développement.

L'évaluation finale doit s'appuyer sur des preuves techniques adaptées à chaque axe : configurations, sorties de commandes, rapports Lynis, scans Nmap, journaux et captures des interfaces de supervision. Les mesures dont l'efficacité n'a pas encore été démontrée sont considérées comme nécessitant une validation complémentaire.

Cette démarche fournit une vision globale du niveau de sécurité de l'infrastructure et permet d'identifier les améliorations prioritaires sans confondre la configuration d'un mécanisme avec la preuve de son efficacité.

Conclusion générale

Ce projet a pour objectif de concevoir et de sécuriser une infrastructure d'entreprise virtualisée en associant segmentation réseau, filtrage, durcissement des systèmes et supervision intelligente. pfSense contrôle les communications entre les zones WAN, LAN, DMZ et MGMT. Le serveur Debian et DVWA permettent de tester l'exposition des services Web et d'observer les traces produites par différentes activités.

Nmap et Lynis permettent d'examiner respectivement les ports accessibles et la configuration de sécurité des systèmes. Suricata complète le dispositif par l'inspection du trafic réseau, tandis que Wazuh centralise les événements des machines surveillées. Le dashboard IA apporte une couche de synthèse destinée à faciliter l'analyse des événements, la compréhension des sévérités et l'identification des mesures correctives.

Les observations disponibles, notamment les ports ouverts lors des scans antérieurs, la réponse HTTP de DVWA, le score Lynis observé et les événements Web remontés dans Wazuh, constituent des éléments de départ pour l'évaluation. La comparaison finale devra être complétée par les scans après durcissement, les audits Lynis finaux et les captures des alertes réellement obtenues.

La réussite du projet repose sur la cohérence entre la conception, la configuration effective, les tests et les preuves documentées. La sécurité ne consiste pas uniquement à fermer des ports ou à installer des outils : elle exige de définir une politique adaptée, de vérifier son application et d'améliorer continuellement la protection de l'infrastructure.